

Seminar Report on Express: Lowering the Cost of Metadata-hiding Communication with Cryptographic Privacy

Carina Fehr (*remember to remove ID for the first draft and peer review!*)

October 6, 2025

Abstract

This report studies the reproducibility and performance of Express, a system for metadata-hiding communication. Using two servers, express provides cryptographic security against at most one malicious server and an arbitrary number of malicious clients. The paper presents new protocols that offer low communication overhead, regardless of the number of users, and improved computation costs using symmetric key cryptography. Compared to Pung and Riposte, two previous cryptographically secure systems, express lowers cost and increases message throughput. This makes Express an ideal applications for communication between whistleblowers and journalists.

1 Introduction

In today's digital landscape, secure communication has become increasingly crucial, with growing capabilities of surveillance and metadata analysis. Secure messaging apps like Signal and Transport Layer Security (TLS) encrypt the content of sent messages, but they do not protect metadata. It is possible to observe who sent and received messages, when and how often they communicated and how much data they exchanged. These information are as sensitive as the message itself and should therefore not be leaked. An option for metadata hiding would be using a TOR browser or SecureDrop, but they are vulnerable to attacks by adversaries that control many network points. Other existing systems to hide metadata either have to high communication cost to be used in reality, or they have low computation cost but their security gets worse with every round of communication, also making them impractical.

While two servers are required, express still runs with one malicious server. Express' target audience are journalists and whistleblowers. To receive messages, a journalist, also called client in the client-server architecture, registers a mailbox with the two servers. The server assigns a 128-bit virtual address to each mailbox and maintains a page table in which it stores the corresponding physical address. The journalist can transmit this address to the whistleblower. Now the client can upload a message into the mailbox. No one except the mailbox owner will know that a message has been sent into this mailbox. Mailbox owners have to check their mailboxes regularly. Express does not hide when a client read from a mailbox, therefore a pattern in the interval of checking could reveal something about activity of this mailbox. Additionally, Express must implement a possibility for cover traffic. This provides whistleblowers with plausible deniability and ensures that they cannot be accused of giving information simply for contacting an Express Server.

There are different types of attacks that Express must be resilient against. All clients can read from all mailboxes, so Express must re-encrypt the mailboxes differently each time a read happens, providing a encryption only the owner can decrypt. All others can neither read the content nor learn anything about which client is writing, even when reading the content of all mailboxes between every pair of writes. Another possible threat would be a malicious client targeting all mailboxes. It could overwrite all mailboxes with one message. Because the mailboxes can only hold a maximum of one message, all messages sent before this will be lost due to this denial-of-server attack. The complete overview is divided between the two servers, which means that the servers alone cannot recognise that this is not a valid message. A new auditing protocol presented in the paper is used to prevent such attacks. However, a malicious client could also attack just one mailbox, in which case the message would be completely correct and the server would have no way of detecting and preventing the attack. Virtual addresses are used to prevent the original messages in the mailbox from being overwritten. The address range is so large that the probability of hitting a specific mailbox is negligible.

2 Background

This section explain the concepts of cryptographic privacy and distributed point functions, also called DPFS. In the following section, we present how they can be used for Express.

2.1 Cryptographic privacy

Cryptographic privacy is a mechanism that guarantees no information leaks. Even after observing many rounds of communication, the adversary knows nothing about which clients are communicating with each other. A different mechanism is differential privacy. After several rounds of communication, they are not able to keep all metadata secret. Therefore, although cryptographic privacy is slower, it is more suitable for a frequently used applications.

2.2 Distributed point function

A DPF (<https://eprint.iacr.org/2023/028.pdf>) is a cryptographic algorithm. It splits a function f into function shares that individually hide f . The point function $f_{a,b}(x)$ outputs b at the point $x = a$ and 0 everywhere else. The two or more parts of the function individually reveal nothing about the function. Express splits the function into two parts, one for each of the servers. Therefore even a malicious server can not tell anything about the function.

3 Private Communication in Express

Explain how clients send and read messages. Describe mailbox registration, writing, and reading steps. Emphasize asynchronous operation and lack of global rounds.

4 Protecting Privacy and Integrity

auditing, malicious client protection, virtual addressing. Explain how these mechanisms maintain security with minimal overhead.

4.1 Express for Whistleblowing

As explained in the previous chapters, Express offers a secure communication option. Outside of the data transfer itself, there are two more safety issues that should be considered. First, we need plausible deniability, second, we need a way to agree on a Mailbox address.

4.1.1 plausible deniability / cover traffic

If whistleblowers were the only users of Express, it would be obvious that anyone who sent a message over Express had passed on information. This means that many users that are not involved in whistleblowing must also send messages, creating cover traffic. To achieve this, a JavaScript program can be integrated into a website with high traffic, such as a news site. Every time a user visits this website, a dummy request is sent to the Express servers. The servers generate a key that is not known to any client. This means that these messages cannot be read, but they also cannot be distinguished from those of the whistleblowers. News websites like New York Times benefit from high cover traffic because whistleblowers feel safer and are more likely to pass on information. This makes such sites particularly suitable for integrating JavaScript. The paper(ref!) does not specify how cover traffic is required exactly, but it should be enough to ensure that real messages remain indistinguishable from the generated ones. The cost and computation times are very low, which can further encourage the use of Express.

4.1.2 Dialing

To select the mailbox address, the journalist and the whistleblower can meet in person. However, this is often not possible. In this case, a dialling protocol can be used. For example, the Riposte system could be used as a basis and made faster and cheaper with the improvements identified in Express. Journalists post their public keys for Riposte online, then whistleblowers can send them a mailbox address. The Journalist can download their messages and register the mailboxes.

5 Related work

Pung: Pung also focuses on metadata hiding in communication systems.

Hier vlt Tabelle mit O notation nehmen und zusätzlich die von Pung und Riposte und vergleichen

Here, you include short descriptions of similar work and explain *how* they are different from the main content you have presented.

Level of detail similar to an abstract.

Note that you may include the related work as a subsection in the Background Section 2.

6 Conclusion

7 Use of generative digital tools

The use of AI tools must always be declared completely and transparently. For examples of how to do this, please see the DMI guidance: https://dmi.unibas.ch/fileadmin/user_upload/dmi/Studium/Computer_Science/Diverses/Wegleitungen/Dokumente_2023/Guidance_on_AI_in_teaching_in_Computer_Science.pdf.

References



University
of Basel

Faculty of Science



Declaration on Scientific Integrity

(including a Declaration on Plagiarism and Fraud)

Translation from German original

Title of Thesis: _____

Name Assessor: _____

Name Student: _____

Matriculation No.: _____

I attest with my signature that I have written this work independently and without outside help. I also attest that the information concerning the sources used in this work is true and complete in every respect. All sources that have been quoted or paraphrased have been marked accordingly.

Additionally, I affirm that any text passages written with the help of AI-supported technology are marked as such, including a reference to the AI-supported program used. This paper may be checked for plagiarism and use of AI-supported technology using the appropriate software. I understand that unethical conduct may lead to a grade of 1 or "fail" or expulsion from the study program.

Place, Date: _____ Student: _____

Will this work, or parts of it, be published?

No

Yes. With my signature I confirm that I agree to a publication of the work (print/digital) in the library, on the research database of the University of Basel and/or on the document server of the department. Likewise, I agree to the bibliographic reference in the catalog SLSP (Swiss Library Service Platform). (cross out as applicable)

Publication as of: _____

Place, Date: _____ Student: _____

Place, Date: _____ Assessor: _____

Please enclose a completed and signed copy of this declaration in your Bachelor's or Master's thesis.

September 2023